



BUG BOUNTY & RESPONSIBLE DISCLOSURE

BY KASTAB GARAI – Founder | Public Speaker | Cyber Trainer

ABOUT ME

I'm Kastab Garai, a Cyber-Security researcher and Founder of the **Bug2Build Community**, a space that empowers hackers, builders, and students to explore technology.

IIT Bombay IIT Roorkee IIT Madras

Govt of India TheSouledStore

CGC University



TODAY'S AGENDA

A walkthrough from bug hunting to responsible disclosure.

01

Bug Bounty – History

02

About Bug Bounty

03

Getting Hands on with Tools

04

Practical Demonstration

05

Responsible Disclosure

06

Thank You

HISTORY OF BUG BOUNTY

1851

ALFRED CHARLES HOBBS

\$20,000

NETSCAPE – launched the first bug bounty program, for the beta version of its Netscape Navigator 2.0 browser

August 2013 – Palestina student reported a vulnerability that allowed anyone to post a video on an arbitrary *Facebook* account.

The student tried to report a vulnerability through Facebook's bug bounty program but was misunderstood.

BUG - BOUNTY

Bug bounty is a program where companies reward people for finding and responsibly reporting security vulnerabilities in their systems, websites, or apps.

Private Bug Bounty **Public Bug Bounty** **Self-Hosted Bug Bounty**
Platform-Based

CVSS

A standard system used to measure the severity of a security vulnerability. It gives a score from 0.0 to 10.0:

CVE

A unique ID number assigned to a publicly disclosed vulnerability.

PRIORITY

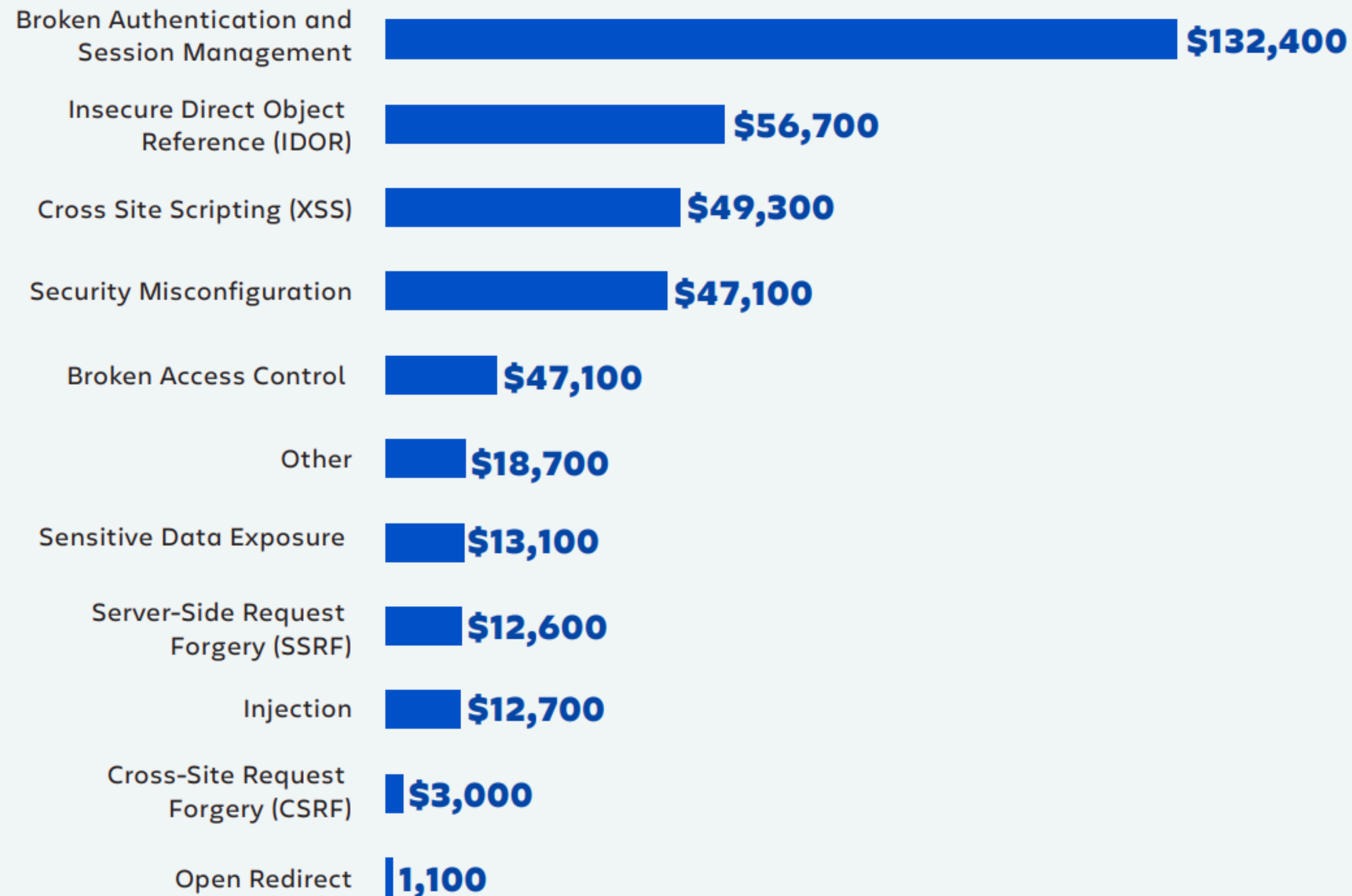
This is how companies rank reported bugs based on risk and business impact.

P1 → Critical
P2 → High
P3 → Medium
P4 → Low

OWASP



FY22 ATLASSIAN BUG-BOUNTY REPORT



TOOLS

Exploit-DB



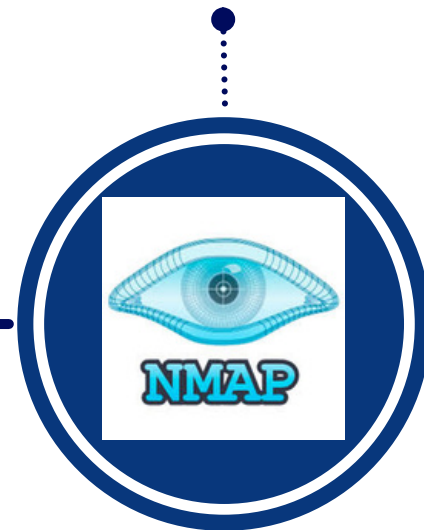
The Exploit Database - Exploits, Shellcode, Odays, Remote Exploits, Local Exploits, Web Apps, Vulnerability Reports, Security Articles, Tutorials and more.

Burpsuite



Burp Suite is an integrated platform for testing the security of web applications. Its tools work together to help map, analyze, and identify vulnerabilities throughout the testing process.

Nmap



Nmap (Network Mapper) is a network scanning tool used to discover hosts and services on a computer network. It helps identify open ports, devices, and potential security vulnerabilities.

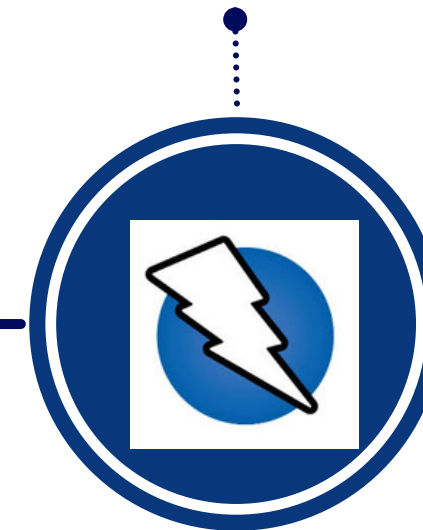


Linux



Kali Linux is a Linux distribution designed for penetration testing and cybersecurity tasks. It includes many tools for network scanning, vulnerability analysis, and ethical hacking. 🛠️🔒

ZAP



OWASP ZAP is an open-source security tool used to find vulnerabilities in web applications. It helps testers scan, detect, and analyze security weaknesses in websites. 🔍👤



**CERTIFIED
PENTESTER**

The background features four decorative blue geometric shapes: a circle in the top-left corner, a large circle in the top-right corner, a large arc in the bottom-left corner, and a small circle in the bottom-left area.

PRACTICAL

DEMONSTRATION

RESPONSIBLE DISCLOSURE



1

Identify the Vulnerability – Discover and verify the security issue in the system or application.

2

Report to the Organization – Privately inform the affected company or developer with detailed information.

3

Allow Time for Fixing – Give the organization reasonable time to investigate and patch the vulnerability

4

Public Disclosure (if needed) – After the issue is fixed, the vulnerability may be publicly disclosed responsibly. 🗝️💻



THANK YOU!

TOGETHER WE CREATE IMPACT

+91 8900348345

